Windows & Active Directory — Résumé, Checklist, Outils et Mesures Préventives

Résumé tel quel (conservé inchangé), checklist, diagramme ASCII, détails sur secretsdump.py, psexec.py / PsExec, et mesures préventives

Résumé tel quel (texte original) :

Windows et Active Directory stockent les informations d’identification dans différents formats et e

Pour les pentesteurs, ces mécanismes de stockage représentent une gamme d'opportunités de collecte,

Mémoire LSASS

Le service LSASS (Local Security Authority Subsystem Service) applique les politiques de sécurité W

Ruches SAM + SYSTEM

La ruche du Gestionnaire de comptes de sécurité (SAM) est une base de données de registre Windows c

Les secrets de la LSA

Windows stocke les secrets LSA sous la clé de registre HKLM\SECURITY\Policy\Secrets, qui contient d

Coffre-fort DPAPI

L' API de protection des données (DPAPI) est un service cryptographique intégré à Windows qui protè

NTDS.dit

NTDS.dit est la base de données principale d'Active Directory, présente uniquement sur les contrôle

Ce tableau résume les magasins que nous ciblerons dans les tâches à venir :

Magasin■Ce qu'il contient■Pourquoi il existe■Méthode d'accès■Outils et commandes
Mémoire LSASS■Hachages NTLM , tickets Kerberos , texte clair (parfois)■Permet une connexion transp
sekurlsa::logonpasswords■sekurlsa::minidump
Ruches SAM + SYSTEM■Hachages de compte locaux■Authentification pour les connexions locales (par ex
lsadump::sam■vssadminextraire
Les secrets de la LSA■Informations d'identification de domaine mises en cache, informations d'ident
Coffre-fort DPAPI■Mots de passe enregistrés à partir d'applications (RDP , navigateurs, WiFi)■Sto
vault::list■vault::cred /exportextraire
NTDS.dit (DC uniquement)■Base de données de domaine complète : noms d'utilisateur, clés NTLM et Ke
secretsdump.py -just-dc■lsadump::dcsync

Nous avons maintenant une bonne vue d'ensemble de l'emplacement et de la finalité du stockage des i

Avant de passer à la tâche suivante, connectons-nous à distance à la machine WRK avec ces informati

Informations d'identification

Nom d'utilisateur

Administrateur

Mot de passe

N3w34829DJdd?1

adresse IP

10.220.10.20
Connexion via

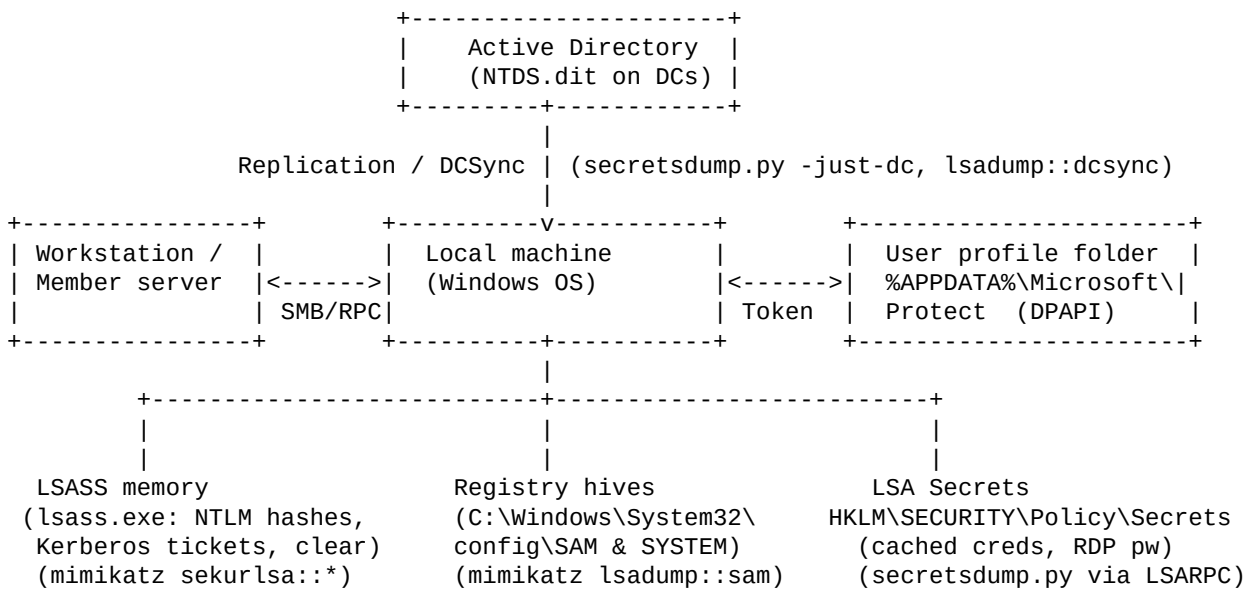
RDP

Checklist pratique (condensé)

Checklist pratique (résumé) - Privilèges requis : SYSTEM pour LSASS, Administrateur local pour SAM/LSA, droits de
réplication pour NTDS. - Outils : mimikatz, secretsdump.py (Impacket), psexec.py (Impacket), PsExec (Sysinternals),
procdump, vssadmin, ntdsutil. - Étapes : shell -> élévation -> dump LSASS -> extraire ruches SAM/SYSTEM ->
secretsdump/DCSync -> récupérer DPAPI keys. - Précautions : EDR/AV détectent mimikatz/psexec; favoriser techniques
stealth et surveillance des événements (7045, 4697, 4624, 4648, 4672).

Diagramme ASCII

Diagramme (ASCII) — Vue d'ensemble



Détails — secretsdump.py

secretsdump.py (Impacket) — utilité et usage - Description : Outil d'Impacket pour extraire hachages et secrets via SMB/LSA/DRSUAPI. - Modes courants : * secretsdump.py user:pass@TARGET -> exfiltration via SMB (si admin) * secretsdump.py -just-dc DOMAIN/USER:PASS@DC -> ciblé DC (NTDS/replication) * secretsdump.py -sam SAM -system SYSTEMfile -> extraction depuis fichiers locaux - Prérequis : compte avec
privilèges suffisants (admin local pour accès SMB, droit de réplication pour DCSync) ou accès aux fichiers hors-ligne. - Exemples : secretsdump.py DOMAIN/admin:Pass@10.220.10.20 secretsdump.py -just-dc domain/replicator:Pass@dc.domain.local - Détection : surveiller appels DRSUAPI/DCSync, accès SMB inhabituels,
transferts de fichiers NTDS.dit.

Détails — psexec.py (Impacket) & PsExec (Sysinternals)

psexec.py (Impacket) vs PsExec (Sysinternals) psexec.py (Impacket) - Outil Python imitant PsExec : création
de service distant via SMB/SCM pour exécuter commande. - Supporte pass-the-hash, scriptable, upload d'exécutable. - Usage : psexec.py DOMAIN/user:Pass@10.220.10.20 psexec.py DOMAIN/user@10.220.10.20 -hashes
: - Traces : création de service distant (event 7045 / 4697), upload de binaire via SMB. PsExec (Sysinternals) - Outil binaire officiel (Microsoft) pour exécution distante, signé. - Usage : psexec \\10.220.10.20 -u Administrator -p "N3w34829DJdd?1" cmd.exe - Traces et détection similaires (création de
service distant), mais signature peut réduire certains blocks AV.

Mesures préventives

Mesures préventives (synthèse actionnable) Spécifique par magasin : - LSASS : Activer LSA Protection (PPL),
déployer Credential Guard, restreindre SeDebugPrivilege, PAW. - SAM/SYSTEM : Restreindre accès NTFS, déployer
LAPS, chiffrer sauvegardes/snapshots. - LSA Secrets : Limiter accès LSARPC, ne pas stocker mots de passe en
clair, vaulting (HashiCorp, CyberArk). - DPAPI : MFA, BitLocker, protéger masterkeys, préférer gestionnaires
de secrets centralisés. - NTDS.dit : Restreindre Replicating Directory Changes, chiffrer sauvegardes DC,
surveillance DCSync. Transverses : - MFA sur comptes admin, segmentation réseau (VLANs/ACLs), AppLocker/WDAC,
EDR comportemental, SIEM centralisé, journaux hors ligne, tests IR. Check-list prioritaire (10 actions) : 1.
Activer MFA admin et consoles. 2. Déployer LAPS. 3. Activer LSA Protection/Credential Guard. 4. Restreindre
droits de réplication. 5. Configurer AppLocker/WDAC pour bloquer mimikatz/psexec.py. 6. Chiffrer sauvegardes
NTDS/SAM/SYSTEM. 7. SIEM + règles (7045, DCSync, dumps). 8. Déployer PAW + séparation comptes. 9. Restreindre
SMB/RPC via firewall. 10. Exercices IR & tests de restauration.

Document généré pour l'utilisateur — contient informations sensibles; stocker et partager avec précaution.